

Phishing Emails in Action

TryHackMe Writeup | Social Engineering Exercise

Course: IKB21403 – Vulnerability Analysis

Topic: Social Engineering (Phishing / Email Analysis)

Platform / Room: TryHackMe – Phishing Emails in Action (phishingemails2rytmuv)

Difficulty: Easy

1. Introduction

Building on the fundamentals, this room moves from theory to practice by examining seven real-world phishing email samples. Each sample impersonates a trusted brand and demonstrates a different combination of tactics – spoofed senders, URL shortening, tracking pixels, credential-harvesting portals and malicious attachments. The aim is to recognise the subtle red flags that separate a routine notification from a sophisticated attack. (As the room warns, the samples contain data from real emails, so links, domains and attachments should never be interacted with directly.)

2. Cancel your PayPal order

This sample mimics a PayPal transaction receipt for a gift-card purchase to create urgency. The display name shows service@paypal.com, but the real sender address is gibberish@sultanbogor.com – an immediate mismatch. The only interactive element is a “Cancel the order” button that points to a shortened URL, hiding its true destination; a tool such as WhereGoes can expand it safely. Reading the receipt body, the listed merchant is Amazing Stuff (an “Amazing Stuff Gift Card” purchase).

Question	Answer
Who is listed as the Merchant in the email body?	Amazing Stuff

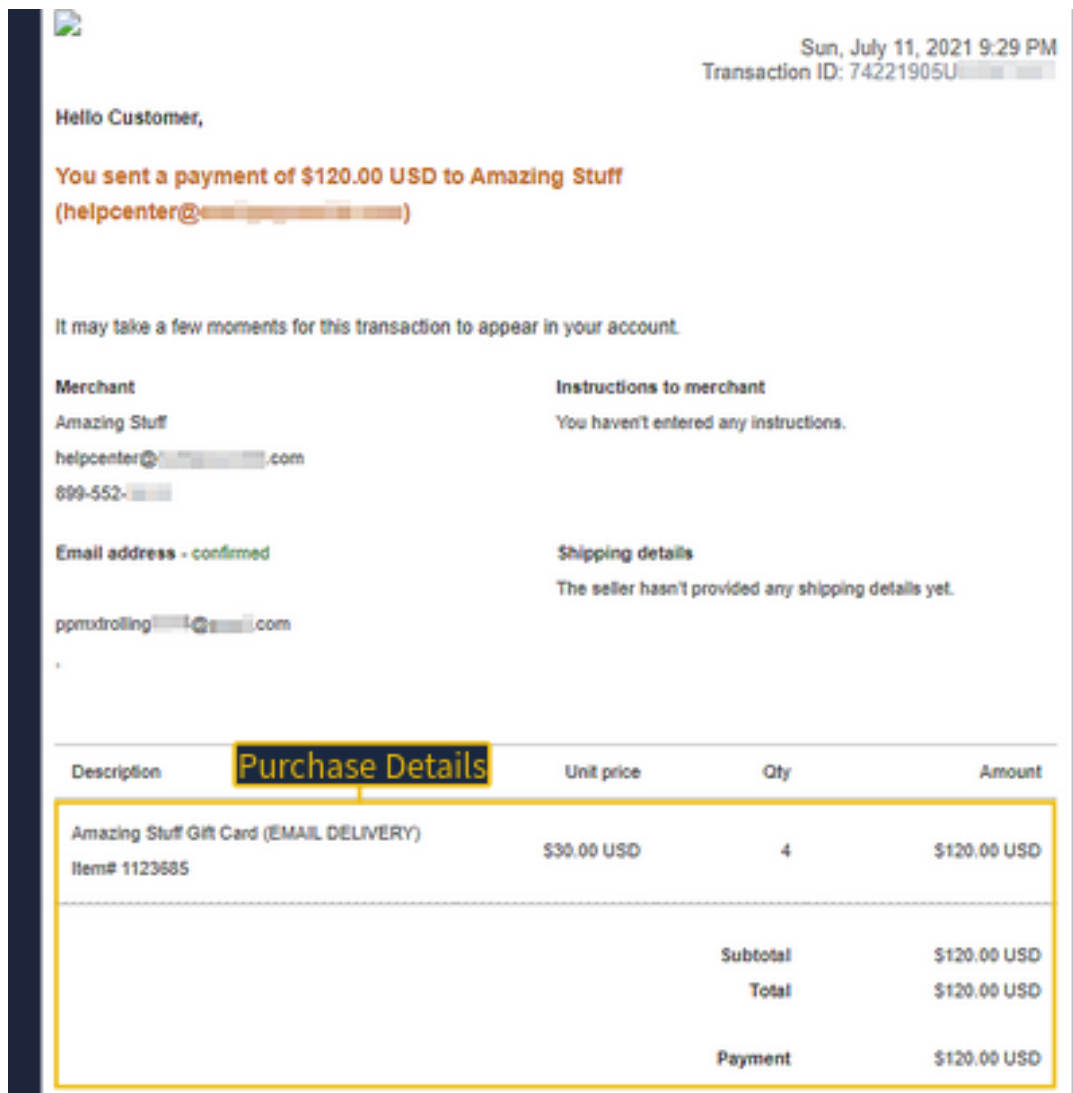


Figure 1: Task 2 – the fake PayPal receipt body listing the merchant “Amazing Stuff”.

3. Track your package

This sample mimics a shipping/distribution-centre notification, using a fake tracking number for urgency. The display name “Distribution Center” does not match the real sender contact@beginpro.club. Because Yahoo blocked the images and disabled the links, the destination is inspected via the raw HTML source instead of hovering. The hyperlink (and the tracking pixel) point to the root domain devret.xyz, which defanged is devret[.]xyz.

Question	Answer
What root domain does the hyperlink point to? (defanged)	devret[.]xyz

email providers do the same.

```

<html>
<body>
  <center>
    <a style="color:#000000" href="http://devret.xyz/4833mt11254939vf6888zq22032s11269du1508rr" >
      <font color=indianred size=5 face=Rockwell> <FONT color="#0000FF" face="arial" size=5 ><strong>
        </FONT><br/><br/>
      </a>
    <br />
    
    <map name="grmk"><br />
      <area shape="rect" coords="0, 0, 1500, 1400" href="http://devret.xyz/4833fx11254939ea6888uk22032mk1269ep1508rr" >
    </map>
    <br />
    
    <map name="unsub">
      <area shape="rect" coords="0, 0, 1500, 1400" href="http://devret.xyz/4833fo11254939iz6888xo22032gu1269fm1508uu" >
    </map>
    <br />
  </center>
</body>
</html>



```

Hyperlink Destination

Display Text

Tracking Pixel

Track your package: # LZ8942357486EN

Answer the questions below

What root domain does the hyperlink in the above example point to?
Be sure to defang the URL.

devret[.]xyz

✓ Correct Answer

Figure 2: Task 3 – raw HTML source showing the hyperlink and tracking pixel pointing to devret[.]xyz.

4. Credential-Harvesting Portal

This sample uses a multi-stage redirection chain that layers trusted brands (OneDrive, Adobe, Microsoft) to build false trust. A “Download Document Here” button with a same-day expiry creates urgency and leads through a fake OneDrive page, then an Adobe-themed page, and finally to a fake login portal. Even valid credentials only return a generic error, because the page is not authenticating the user – it simply forwards the captured username and password to the attacker. This technique is called credential harvesting.

Question	Answer
The attacker deployed a fake portal to capture and exfiltrate credentials. What is this attack called?	Credential Harvesting

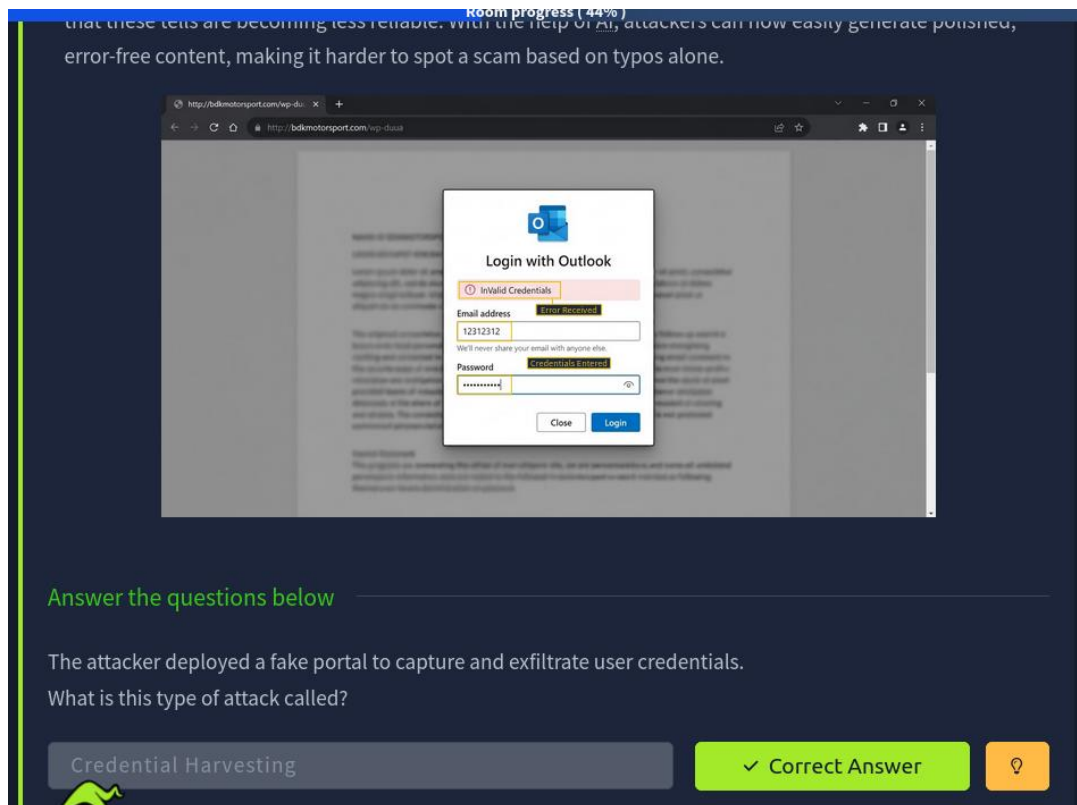


Figure 3: Task 4 – the fake “Login with Outlook” portal used to harvest credentials.

5. Netflix billing

This sample impersonates Netflix billing, claiming the account is suspended to pressure the victim. Instead of a direct link, it hides the malicious URL inside a PDF attachment containing an “Update Payment Account” link that points to a non-Netflix domain. Other red flags include misspellings of Netflix and an atypical phone-number format. Behind the display name “Netltx billing”, the actual sender address is z99@musacombi.online.

Question	Answer
What is the actual sender email address behind the “Netltx billing” display name?	z99@musacombi.online

a legitimate Netflix domain. we will investigate this email in detail in the next room of this module, [Phishing Analysis Tools](#). There are a couple other of points of interest worth noting.

1. The use of an atypical phone number format is a red flag
2. Using a legitimate Netflix help center domain to build a false sense of trust

Please update your payment details

Hello Customer,

We're having some trouble with your current billing information. Please open file [PDF] to update your account.

Need help? We're here if you need it. Visit the Help Center or contact us now.

~Your friends at Netflix

Questions? Call 800-832-2135

Please do not reply to this email, as we are unable to respond from this email address. If you need help or would like to contact us, please visit our help center at <https://help.netflix.com>

Payment up...pdf

Update Payment Account

If you did not ask to reset your password you may want to review your [recent account access](#) for any unusual activity.

We're here to help if you need it. Visit the [Help Center](#) for more info or [contact us](#).

- Your friends at Netflix

Answer the questions below

What is the actual sender email address hidden behind the **Netllx billing** display name?

✓ Correct Answer 💡

Figure 4: Task 5 – the Netflix-themed email body and PDF attachment; the real sender is z99@musacombi.online.

6. Apple Support attachment (BCC)

This sample impersonates Apple Support with an “Action Required” unauthorised-purchase notice. The body is completely blank – suspicious on its own – and the victim is not addressed directly but Blind Carbon Copied (BCC), a way to hide the true recipient list. The only content is an attachment in the unusual .dot format (a Microsoft Word Template); interacting with its embedded image redirects to a phishing site with a long, obfuscated URL.

Question	Answer
What does the acronym BCC stand for?	Blind Carbon Copy
What is the file extension of the attachment?	.dot

Room progress (77%)

a `.dot` file, so let's investigate further. When the user interacts with the large image embedded in the document, they are redirected to a phishing site. Although the URL includes familiar terms like **apps** and **ios** to appear legitimate, its excessive length and complexity are strong indicators of a malicious redirection attempt.



Attachment

Redirect Link

<https://tumblr.com/redirect?url=https://apple-ic-games.mansiea.com/?qjshwz0dd8vsmvrtngqsdmfmwjkndtjpdgjmde2z0ffmymtredkddomuhlmzqjsehmddlmstc7y2zjpmrmdvwyvzdzgyrdmzytmynotc2mk2m2m>

Ctrl + Click to follow link

Save 3% on all your Apple purchases with Apple Card. Apply and use in minutes.

APPLE ID: example@appleid.com	DATE: Apr 03, 2020	ORDER ID: MN HLSF 45X G
DOCUMENT NO.: 137320441420	BILLED TO: [123 Pine St., Springfield, IL 62704, USA]	

App Store

Product Icon	Product Details	Price
	Title: Double Jackpot Slots Las Vegas, Large pack of coins Type: In-App Purchase Device: iPhone	\$14.99

[Report a Problem](#)

Large Image

Answer the questions below

What does the acronym BCC stand for?

Blind Carbon Copy

✓ Correct Answer

What is the file extension of the attachment?

.dot

✓ Correct Answer

Figure 5: Task 6 – the Apple-themed `.dot` attachment with an embedded redirect link.

7. DHL Excel payload

The final sample impersonates DHL Express with branded HTML and funnels the victim toward a malicious Excel (`.xlsx`) attachment. The document shows conflicting geographic markers (a German sender domain, an invoice addressed to India, content in Mandarin) – classic red flags. A single link inside the spreadsheet attempts to download and execute a payload named `regasms.exe`. Although it errors out in this environment, the intent is clear: code execution that could establish persistence, exfiltrate data, or deploy ransomware.

Question	Answer
What is the name of the executable the Excel attachment attempts to run?	regasms.exe

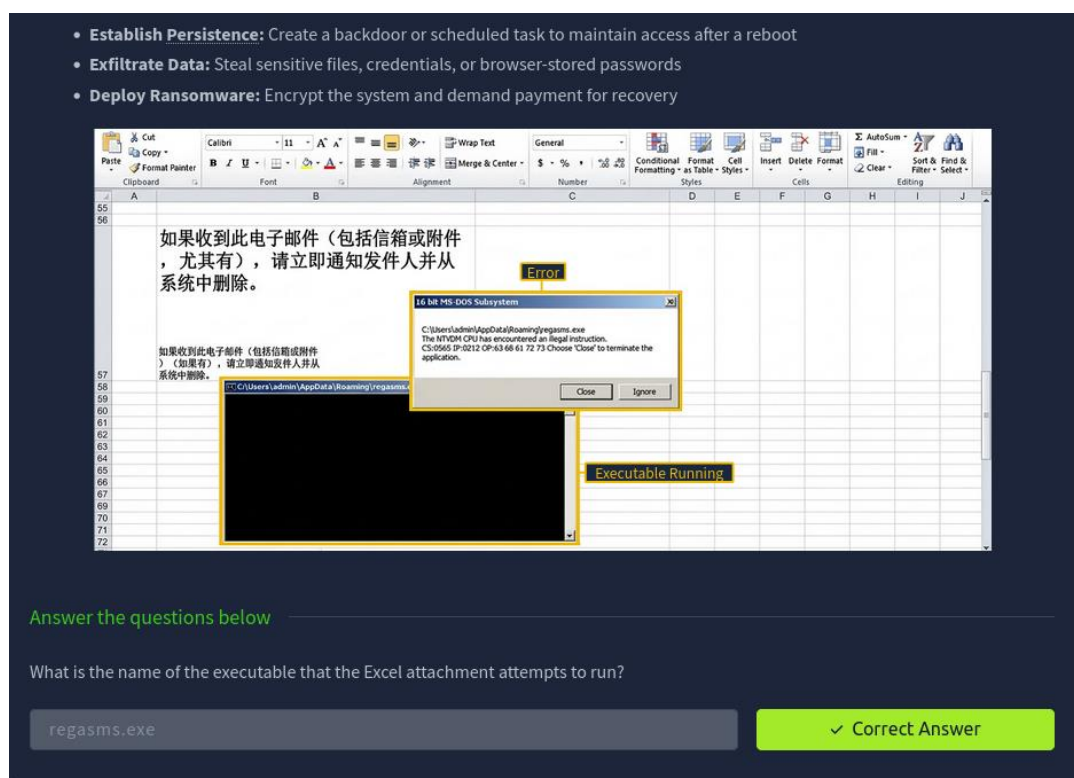


Figure 6: Task 7 – the DHL Excel attachment attempting to execute regasms.exe (16-bit MS-DOS error shown).

8. Conclusion & Key Takeaways

Across seven samples, this room showed how attackers mirror legitimate communications using spoofed senders, URL shortening, tracking pixels, redirection chains, credential-harvesting portals, and malicious attachments. The recurring lesson is that every layer should be verified independently – the display name, the real sender address, the true link destination, and the attachment type – rather than trusting the email's appearance.

- Always compare the display name against the real sender address; a mismatch is a primary red flag.
- Expand shortened links and inspect raw HTML instead of clicking; defang URLs and IPs before recording them.
- Treat unexpected attachments (.dot, .xlsx with macros, PDFs with embedded links) as hostile until proven otherwise.
- Urgency, brand impersonation and credential-harvesting portals are the core social engineering levers studied in IKB21403.